

Análisis de Seguridad

Pruebas dinámicas (DAST) y configuración segura
aplicadas al proyecto ISO SECURE

Agustín Peralta
BACKEND & ARQUITECTURA

Natalia Moncaleano
MODELO DE AMENAZAS

Johan Salazar
HARDENING & DEVSECOPS

¿Qué es ISO SECURE?

Plataforma web para gestionar el **Sistema de Gestión de Seguridad de la Información (SGSI)** conforme a **ISO/IEC 27001:2022**. Multi-tenant, con 4 roles y 9 módulos operacionales.

93

CONTROLES ISO PRECARGADOS

39

ENDPOINTS API REST

24

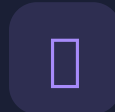
AMENAZAS CATALOGADAS

15

RIESGOS IDENTIFICADOS

● <https://iso-secure.agustinynatalia.site>

¿Por qué **DAST** si ya hicimos SAST?

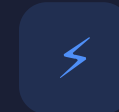


SAST

Static Application Security Testing

- ▶ Lee el código fuente
- ▶ Detecta patrones peligrosos
- ▶ ruff, bandit, semgrep
- ▶ Hecho en Etapa 3

VS



DAST

Dynamic Application Security Testing

- ▶ Ataca la app corriendo
- ▶ Encuentra problemas de runtime
- ▶ OWASP ZAP, Nuclei, sqlmap
- ▶ Esta etapa

Ambos son obligatorios. Detectan cosas distintas.

Las herramientas del DAST

< GENERAL

OWASP ZAP

Proxy interceptor + spider + scan activo con cientos de payloads. El "todo en uno" del DAST.

▣ PLANTILLAS

Nuclei

Ejecuta plantillas YAML mantenidas por la comunidad. Una plantilla = una vulnerabilidad o misconfig.

▣ INYECCIÓN

sqlmap

Detecta y explota automáticamente todos los tipos de SQL injection: error-based, blind, time-based.

▣ TLS

testssl.sh

Auditoría completa de TLS: protocolos, suites de cifrado, certificados y CVEs conocidos.

▣ FUZZING

ffuf

Fuzzer web ultrarápido. Descubre endpoints y parámetros ocultos con miles de peticiones.

▣ AUTH

JWT_Tool

Toolkit específico para JWT: firma débil, alg=none, kid traversal, falsificación.

Estrategia: ataque en 4 capas

No se ataca todo de golpe. Se avanza por capas, cada una asumiendo más conocimiento del sistema.

CAPA 1

Reconocimiento

Sin login. Lo que un atacante anónimo ve.

- ▶ Spider de ZAP
- ▶ Archivos sensibles (.git, .env)
- ▶ TLS audit
- ▶ Versiones expuestas

CAPA 2

Autenticación

Atacar el login.

- ▶ Enumeración de usuarios
- ▶ Brute force
- ▶ Credential stuffing
- ▶ JWT (alg=none, exp)

CAPA 3

Autorizado

Con cuenta válida de bajo privilegio.

- ▶ IDOR (cambiar IDs)
- ▶ Cross-tenant
- ▶ Privilege escalation
- ▶ Tamper de parámetros

CAPA 4

Fuzzing

Peticiones masivas con datos absurdos.

- ▶ Strings 1MB, ints negativos
- ▶ SQL/NoSQL/SSTI
- ▶ Unicode/emojis
- ▶ Edge cases

Catálogo de hallazgos y mitigaciones

ID	HALLAZGO	SEVERIDAD	MITIGACIÓN APLICADA
D-10	JWT alg=none aceptado	CRÍTICA	Validación contra Supabase /auth/v1/user
D-11	IDOR en /incidents/{id}	CRÍTICA	Verificación de ownership en service layer
D-12	Bypass cross-tenant via parámetro	CRÍTICA	Helper _empresa_filter infiere del JWT
D-01	Cookies sin HttpOnly/Secure	ALTA	HttpOnly + Secure + SameSite=Lax
D-02	CORS demasiado permisivo (*)	ALTA	Whitelist explícita por entorno
D-07	TLS 1.0 / 1.1 habilitado	ALTA	Solo TLS 1.2+ (ideal 1.3)
D-09	Brute force sin logout	ALTA	Rate limit Nginx + logout Supabase
D-13	SSRF en webhooks n8n	ALTA	Allowlist de hosts salientes
D-15	Falta de rate limit global	ALTA	slowapi + Nginx limit_req
D-03	Cabeceras de seguridad faltantes	MEDIA	Nginx con CSP, HSTS, X-Frame, X-Content-Type
D-04	Stack traces en producción	MEDIA	DEBUG=False + handler genérico

Hardening por capa

DAST encuentra el problema. El hardening lo previene. Endurecimos cada capa de la pila.

□ Frontend (React)	Sin source maps en prod · SRI en scripts externos · sólo variables VITE_* públicas	SECURE
⚡ FastAPI	DEBUG=False · docs_url=None · Trusted Hosts middleware · request_id en logs · GZip con minimum_size	SECURE
□ Nginx	TLS 1.3 · Mozilla intermediate · server_tokens off · Rate limit · CSP/HSTS/X-Frame headers	HARDENED
□ Docker	Multi-stage · USER 10001 (no-root) · cap-drop=ALL · Read-only FS · Trivy scan obligatorio	HARDENED
□ PostgreSQL	sslmode=require · Roles separados (app/migrator) · RLS · PITR 7 días · Encriptación at-rest	HARDENED
□ Sistema Operativo	Debian slim · unattended-upgrades · SSH solo claves · ufw (22/80/443) · fail2ban · auditd	HARDENED

Cabeceras HTTP de seguridad

Aquí se ganan o pierden la mayoría de los puntos en una auditoría DAST.

```
# nginx.conf – extracto real
add_header Strict-Transport-Security "max-age=31536000; includeSubDomains; preload" always;
add_header X-Content-Type-Options "nosniff" always;
add_header X-Frame-Options "DENY" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "geolocation=(), microphone=(), camera=()" always;
add_header Content-Security-Policy "default-src 'self';
    script-src 'self' 'unsafe-inline';
    connect-src 'self' https://*.supabase.co;
    frame-ancestors 'none';" always;

# Ocultar versión del servidor
server_tokens off;
```


Secretos & Despliegue **blue-green**

■ GESTIÓN DE SECRETOS

Reglas estrictas

- ▶ Nunca en el código (detect-secrets en pre-commit)
- ▶ Nunca en logs (filtros de redacción)
- ▶ Rotación cada 90 días
- ▶ Mínimo privilegio por servicio
- ▶ Vault del proveedor (Supabase, Coolify)

■ BLUE-GREEN

Despliegue sin downtime

- ▶ Coolify levanta versión "green" en paralelo
- ▶ Healthcheck /health debe pasar
- ▶ Swap automático de tráfico blue→green
- ▶ Rollback si falla healthcheck
- ▶ Cero downtime, cero riesgo

git push origin main → Coolify detecta → build → healthcheck → swap → URL viva

Respuesta a incidentes

Por bien que esté todo, hay que asumir que un día algo falla. Plan documentado con SLA por severidad.

P0

Crítico

Brecha activa · indisponibilidad total · fuga de datos

15 min

P1

Alto

Vuln explotable confirmada · degradación severa

1 h

P2

Medio

Vuln sin exploit público · función no crítica caída

4 h

P3

Bajo

Hardening pendiente · hallazgo informativo

5 días

Procedimiento (6 pasos)

1. Detección
2. Triage
3. Contención
4. Erradicación
5. Recuperación
6. Lecciones

Cumplimiento ISO/IEC 27001:2022

La Etapa 4 cubre técnicamente estos controles del Anexo A.

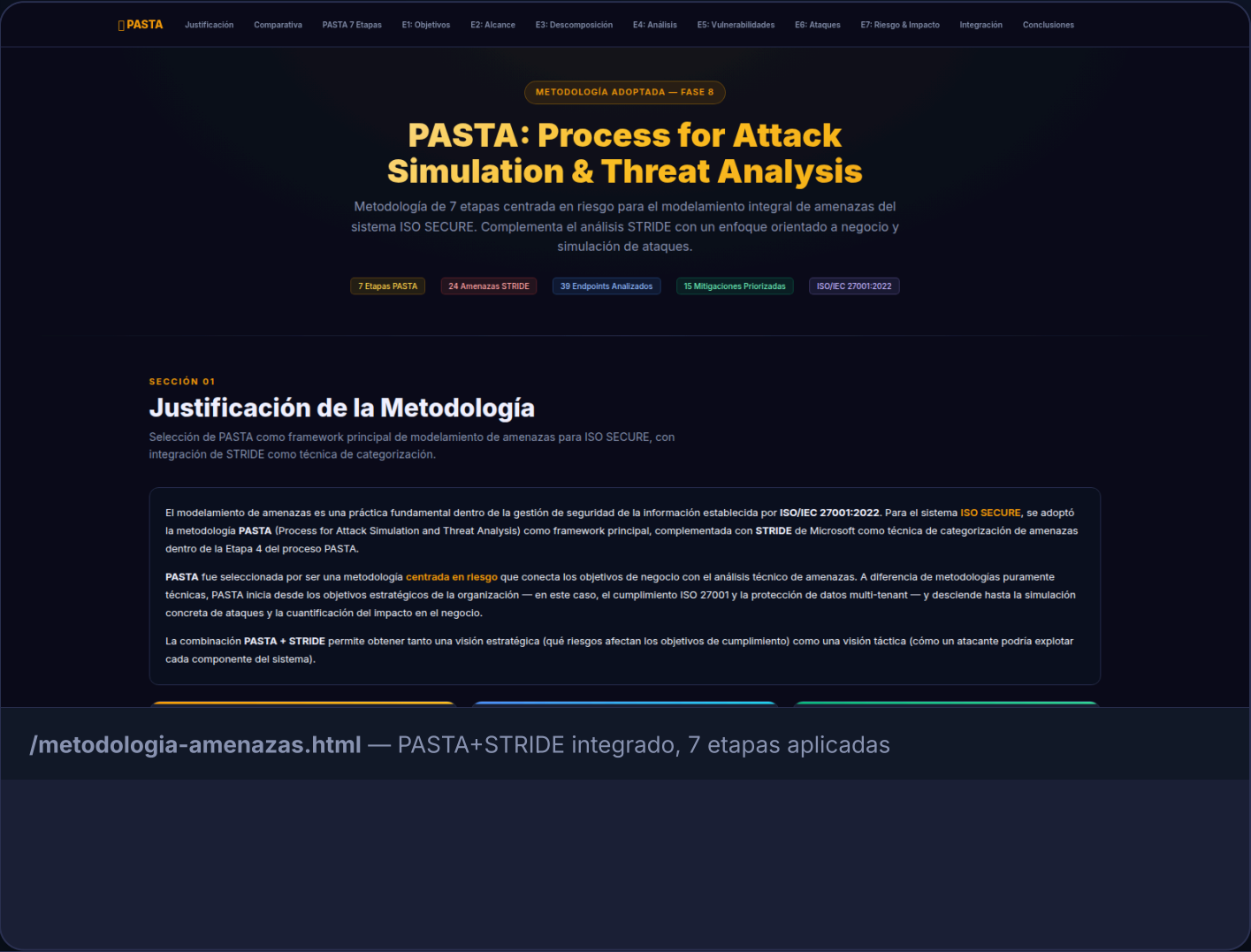
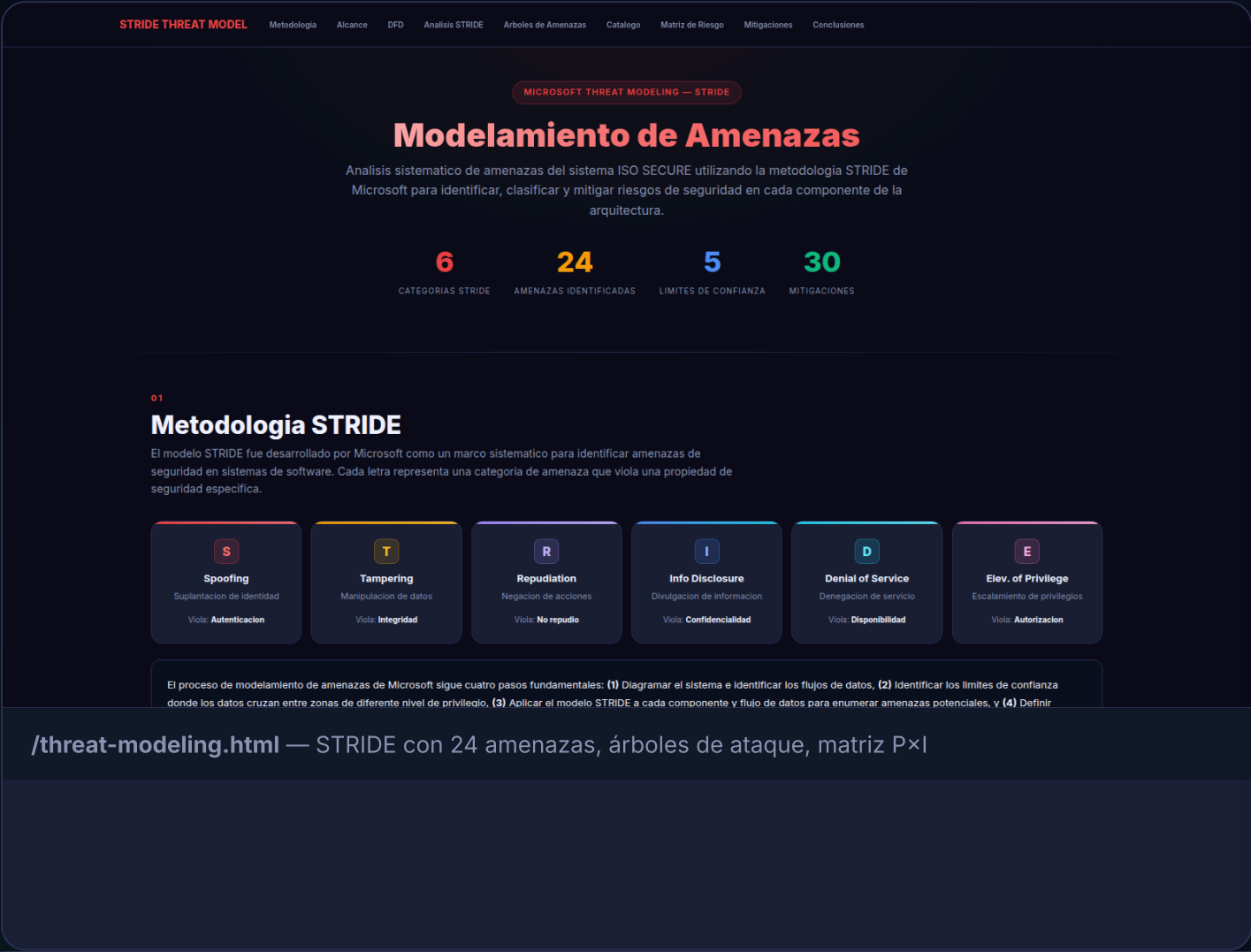
CONTROL	CUBIERTO POR
A.5.24-A.5.28	Procedimiento IR + SLAs
A.5.30	PITR + RPO 1h / RTO 2h
A.8.7	Trivy en CI
A.8.8	DAST ZAP + Nuclei
A.8.9	Coolify + vault
A.8.13	Backup diario + PITR
A.8.15	Logs JSON · 90d retención

CONTROL	CUBIERTO POR
A.8.16	Prometheus + alertas
A.8.20	TLS 1.3 + ufw + rate limit
A.8.23	CSP estricto + CORS allowlist
A.8.24	TLS 1.3 + JWT RS256
A.8.26	DAST como gate de release
A.8.27	Hardening por capa
A.8.29	DAST automatizado

~14 controles del Anexo A cubiertos sólo en esta etapa.

Modelado de amenazas en vivo

Las páginas de documentación están desplegadas y son públicas. Capturas reales del sitio:



Arquitectura y API en vivo

ISO SECURE

Arquitectura GeneralBackendFrontendStack TecnológicoDespliegueAutenticaciónModelo de Datos

DOCUMENTO DE ARQUITECTURA

ISO SECURE

Plataforma de Cumplimiento ISO 27001 — Arquitectura completa del sistema, tecnologías adoptadas y diseño de cada capa

39

API ENDPOINTS

9

MODULOS

9

TABLAS DB

4

ROLES RBAC

93

CONTROLES ISO

01

Arquitectura General del Sistema

Vision de alto nivel: flujo de datos desde el cliente hasta la base de datos y servicios externos.

Navegador Web

Chrome / Firefox / Edge

HTTPS

Puerto 3000

Dispositivo Movil

Responsive Design

Mobile First

HTTP/HTTPS Requests

/arquitectura.html — capas, backend, frontend, stack, despliegue, RBAC, ER

Volver al Dashboard

ISO_SECURE 27001

v2.0.0 — Production

FastAPIPostgreSQLPydantic v2SQLAlchemyUvicorn

SGSI KPI API

// API de Indicadores y Métricas de Seguridad

ECOSISTEMA DE INDICADORES SGSI (ISO/IEC 27001)

KPI (Key Performance Indicator): Mide resultados ya ocurridos
Eje.: 85% de incidentes resueltos este mes

KRI (Key Risk Indicator): Predice riesgos futuros
Ejem: Dominio A.9 con score de riesgo 18/25

GESTIÓN DE INCIDENTES
"¿Cuántos incidentes hubo y cuánto tardamos en cerrarlos?"

CONFORMIDAD DE CONTROLES
"¿Cuántos controles ISO 27001 estamos cumpliendo?"

GESTIÓN DEL RIESGO
"¿Qué tan expuesta está la organización?"

ISO 27001 Cláusula 9.1 (Monitoreo y medición)

ISO 27001 Cláusula 9.3 (Revisión o medición)

ISO 27005 (matriz probabilidad x impacto)

ISO 27001 Cláusula 9.3 (Revisión por la dirección)

DASHBOARD RESUMEN

CICLO DE MEDICIÓN ISO 27004

Cada KPI tiene fórmula, fuente, periodicidad y umbral verde/verde/ámbar/rojo

FLUJO DE AUTENTICACIÓN Y AUTORIZACIÓN

/docs.html — documentación interactiva de los 39 endpoints REST

● <https://iso-secure.agustinynatalia.site>

Frontend SPA + Backend FastAPI

Coolify · TLS 1.3

Seguridad **en runtime**

La seguridad no se decide al elegir framework.
Se decide en runtime, en la infraestructura y en los procesos.

*"Si no probaste el sistema en producción **atacándolo tú mismo**, no sabés qué tan seguro es. Lo demás es opinión."*

Agustín Peralta
BACKEND & ARQUITECTURA

Natalia Moncaleano
MODELO DE AMENAZAS

Johan Salazar
HARDENING & DEVSECOPS

● <https://iso-secure.agustinynatalia.site>